

Fiche ressource n°2 — IA, RGPD et IA Act : ce que le responsable engage

Document remis aux participants. Les références réglementaires doivent être vérifiées à leur version en vigueur à la date de consultation.

1. Comprendre une IA générative en trois minutes

Une IA générative ne « sait » rien. Elle a été entraînée sur d'immenses volumes de textes et calcule, mot après mot, la suite la plus probable à ce que vous avez écrit. Elle n'a ni intention, ni conscience, ni accès à une vérité de référence.

La conséquence directe pour un manager

Elle formule toujours avec assurance, y compris quand elle se trompe.

Le ton convaincant n'est pas un indice de fiabilité : c'est une propriété du modèle.

Vous restez l'auteur et le responsable de tout ce que vous validez.

Les trois pièges à connaître

Piège	Ce qui se passe	Ce que vous faites
L'hallucination	Elle invente un chiffre, un article de loi, une citation, un nom	Ne jamais reprendre une donnée chiffrée ou juridique sans vérifier à la source
Le biais	Elle reproduit les régularités de ses données, y compris discriminatoires	Ne jamais lui faire trier des personnes sans contrôle humain réel
La fuite	Ce que vous saisissez peut être conservé, réutilisé, hébergé hors UE	Aucune donnée que vous n'afficheriez pas sur le mur de la salle de pause

Ce qu'elle fait bien, ce qu'elle fait mal

Fiche ressource n°2 — IA, RGPD et IA Act

Comprendre l'IA, protéger les données, situer les usages, agir en déployeur

Confiez-lui sans crainte	Ne lui confiez jamais
Reformuler, résumer, structurer un plan Traduire, corriger, harmoniser un ton Produire 20 variantes d'une même idée Préparer une liste de questions	Un chiffre ou une référence juridique non vérifiée Une décision concernant une personne Un diagnostic humain ou médical Le dernier mot sur quoi que ce soit

2. RGPD : l'essentiel pour un responsable d'équipe

Le RGPD — Règlement (UE) 2016/679, applicable depuis le 25 mai 2018 — encadre tout traitement de données permettant d'identifier une personne, directement ou indirectement : nom, e-mail professionnel nominatif, photo, matricule, adresse IP, géolocalisation.

Les six réflexes

Principe	La question que vous vous posez	Référence
Finalité	Pourquoi je collecte cette donnée, précisément ?	Art. 5.1.b
Base légale	Sur quel fondement ai-je le droit ? (contrat, obligation légale, intérêt légitime...)	Art. 6
Minimisation	Ai-je vraiment besoin de tout ça pour cette finalité ?	Art. 5.1.c
Conservation	Pendant combien de temps ? Qui supprime, et quand ?	Art. 5.1.e
Transparence	Les personnes sont-elles informées, en langage clair ?	Art. 12 à 14
Sécurité	Qui y accède ? Comment est-ce protégé ?	Art. 32

Le piège du consentement du salarié

En entreprise, le consentement d'un salarié est rarement une base légale valable : le lien de subordination rend le consentement difficilement « libre ».

Cherchez plutôt : exécution du contrat, obligation légale, ou intérêt légitime documenté.

Surveiller, contrôler, évaluer : les limites

- **Pas de collecte à l'insu du salarié** — Code du travail, art. L.1222-4 : aucune information concernant personnellement un salarié ne peut être collectée par un dispositif qui n'a pas été porté préalablement à sa connaissance.
- **Information et consultation du CSE** — Code du travail, art. L.2312-38 : préalablement à la mise en œuvre de moyens ou techniques permettant un contrôle de l'activité des salariés.
- **Proportionnalité** : le contrôle doit être justifié par la nature de la tâche et proportionné au but recherché. Une surveillance permanente et généralisée d'un poste de travail est disproportionnée.
- **Durée** : les données de contrôle ne se conservent pas « au cas où ».

Source : CNIL, fiches pratiques sur le travail et les données des salariés (cnil.fr) ; Légifrance, Code du travail.

L'article 22 : la décision automatisée

Une personne a le droit de ne pas faire l'objet d'une décision fondée **exclusivement** sur un traitement automatisé produisant des effets juridiques la concernant ou l'affectant de manière significative. C'est l'article qui relie directement le RGPD à l'IA Act.

- Concrètement : tri automatique de CV, refus automatique, sanction calculée par un outil.
- Il faut un humain qui dispose du temps, de la compétence et du **droit** de dire non.
- Un humain qui valide tout sans jamais contredire l'outil n'est pas une garantie : c'est une supervision de façade.

3. L'IA Act : classer les usages, pas les outils

Règlement (UE) 2024/1689, entré en vigueur le 1^{er} août 2024, d'application progressive. Il ne qualifie pas un logiciel en lui-même : il qualifie l'**usage** qui en est fait. Le même outil peut être à risque minimal pour rédiger un compte rendu, et à haut risque pour trier des candidatures.

Les deux rôles

- **Fournisseur** : celui qui développe ou fait développer le système et le met sur le marché.
- **Déployeur** : celui qui utilise le système sous sa propre autorité. **C'est presque toujours votre rôle.**
- **Attention** : modifier substantiellement un système, ou le diffuser sous votre marque, peut vous faire basculer dans le rôle de fournisseur, avec des obligations bien plus lourdes.

Les quatre niveaux de risque

Niveau	Exemples pour un manager	Régime
Inacceptable	Détection des émotions des salariés sur le lieu de travail ; notation sociale ; exploitation d'une vulnérabilité	Interdit (art. 5)
Haut risque	Tri et classement de candidatures ; décisions de promotion ou de rupture ; répartition automatisée des tâches ; suivi et évaluation de la performance	Autorisé mais fortement encadré (annexe III, pt 4)
Risque limité	Agent conversationnel, contenus générés, images ou vidéos synthétiques	Obligation de transparence (art. 50)
Risque minimal	Résumer une note interne, reformuler une consigne, traduire	Usage libre

Interdictions qui concernent directement le management

Reconnaître ou déduire les émotions des salariés sur le lieu de travail — sauf raisons médicales ou de sécurité. Une solution qui « mesure l'engagement » ou « l'attention » en réunion entre dans le champ de l'interdiction.

Fiche ressource n°2 — IA, RGPD et IA Act

Comprendre l'IA, protéger les données, situer les usages, agir en déployeur

Noter socialement les personnes à partir de comportements sans rapport avec la finalité.

Exploiter une vulnérabilité (âge, handicap, situation économique) pour influencer un comportement.

Référence : IA Act, article 5. Applicable depuis le 2 février 2025.

Vos obligations de déployeur (art. 26)

1. **Savoir** quels systèmes d'IA sont utilisés dans votre périmètre, et pour quoi.
2. **Utiliser conformément** à la notice d'utilisation du fournisseur.
3. **Garantir une supervision humaine** effective, confiée à une personne compétente.
4. **Informers les travailleurs et leurs représentants** avant la mise en service d'un système à haut risque sur le lieu de travail.
5. **Informers les personnes** soumises à une décision prise avec l'aide du système.
6. **Conserver les journaux** et tracer qui a décidé quoi, et quand.

L'article 4 : la littératie en matière d'IA

Une obligation qui vous concerne dès aujourd'hui

Les fournisseurs et les déployeurs prennent des mesures pour assurer, autant que possible, un niveau suffisant de maîtrise de l'IA de leur personnel et des personnes qui utilisent les systèmes pour leur compte.

Ce niveau s'apprécie selon les connaissances, l'expérience, la formation, le contexte d'usage et les personnes concernées.

Applicable depuis le 2 février 2025. Aucune exemption liée à la taille de l'entreprise.

Conservez la trace de cette journée : émargement, programme, évaluation. C'est un commencement de preuve.

Le calendrier d'application

Date	Ce qui s'applique
1 ^{er} août 2024	Entrée en vigueur du règlement
2 février 2025	Pratiques interdites (art. 5) et littératie en matière d'IA (art. 4)

Date	Ce qui s'applique
2 août 2025	Modèles d'IA à usage général, gouvernance, régime de sanctions
2 août 2026	Application générale, dont les systèmes à haut risque de l'annexe III
2 août 2027	Systèmes à haut risque intégrés à des produits réglementés (annexe I)

Point de vigilance : ce calendrier a fait l'objet de discussions européennes visant à amender certaines échéances. Vérifiez l'état du droit à la date où vous engagez un projet.

Source : Règlement (UE) 2024/1689, Journal officiel de l'Union européenne ; Commission européenne, page « AI Act » (digital-strategy.ec.europa.eu).

Les sanctions

Manquement	Plafond
Pratique interdite (art. 5)	35 M€ ou 7 % du chiffre d'affaires annuel mondial
Autres obligations IA Act	15 M€ ou 3 % du chiffre d'affaires annuel mondial
Manquement RGPD	20 M€ ou 4 % du chiffre d'affaires annuel mondial

Le montant le plus élevé s'applique. Pour une PME, le risque réel est rarement l'amende plafond : c'est le contentieux prud'homal, le conflit social et l'atteinte à l'image.

4. Les trois réflexes avant de lancer un usage d'IA

La question	Si la réponse est oui
1. Y a-t-il des données personnelles dans ce que je saisis ou ce qui sort ?	RGPD : je définis la finalité, la base légale, la durée, j'informe les personnes, j'inscris le traitement au registre (art. 30) et j'examine la nécessité d'une analyse d'impact (art. 35).
2. L'usage influence-t-il une décision concernant une personne (recrutement, évaluation, affectation, sanction, rupture) ?	IA Act : usage à haut risque. Supervision humaine effective obligatoire, information des travailleurs et de leurs représentants, traçabilité. RGPD art. 22 en parallèle.
3. Où sont hébergées et traitées les données ?	Hors UE : je vérifie l'encadrement du transfert (chapitre V du RGPD) et le droit auquel le prestataire est soumis. Un hébergement en UE ne suffit pas si l'éditeur relève d'une législation extraterritoriale.

5. Les quatre questions à poser à tout fournisseur, par écrit

1. Où mes données sont-elles stockées et traitées, y compris pour la maintenance et les sauvegardes ?
2. Qui peut y accéder, et sous quelle législation cet accès peut-il être ordonné ?
3. Mes données servent-elles à entraîner ou améliorer des modèles ? Puis-je m'y opposer ?
4. Puis-je exporter l'intégralité de mes données et obtenir leur suppression à la fin du contrat ?

Exigez ces réponses dans le contrat ou l'accord de sous-traitance (RGPD, art. 28), pas dans un échange commercial oral.

6. Où l'IA vous rend réellement du temps

Usage	Gain typique	Condition de conformité
Structurer un compte rendu à partir de vos notes	20 à 40 min par réunion	Anonymiser les noms, ne pas traiter d'avis sur des personnes
Préparer un entretien difficile (scénarios, questions)	30 min	Cas décrit sans élément identifiant

Usage	Gain typique	Condition de conformité
Rédiger une trame de procédure ou un mode opératoire	1 à 2 h	Relecture métier obligatoire avant diffusion
Reformuler une consigne pour trois publics différents	20 min	Aucune donnée personnelle
Interroger un document long (appel d'offres, accord)	1 h	Vérifier toute citation dans le document source

Un bon prompt tient en quatre blocs

1. **Rôle** : « Tu es responsable qualité dans une PME industrielle de 40 personnes. »
2. **Contexte** : secteur, taille, contrainte, public destinataire, ce qui a déjà été tenté.
3. **Tâche** : un seul verbe d'action, très précis. « Rédige », « compare », « liste ».
4. **Format** : longueur, plan attendu, ton, ce qu'il ne faut pas faire.
5. Et toujours, en dernière ligne : « Si une information te manque, pose-moi la question au lieu de l'inventer. »

La règle qui vous protège

Le prompt est un brief. Un brief flou donne un travail flou — exactement comme avec un humain.

Vous êtes l'auteur de ce que vous diffusez. L'outil n'est jamais responsable.

Sources

- Règlement (UE) 2016/679 (RGPD) — Journal officiel de l'Union européenne.
- Règlement (UE) 2024/1689 (IA Act) — Journal officiel de l'Union européenne.
- Commission européenne — dossier « AI Act » (digital-strategy.ec.europa.eu).
- CNIL — fiches « Travail et données personnelles » et publications sur l'IA (cnil.fr).
- Légifrance — Code du travail, articles L.1222-4 et L.2312-38 (legifrance.gouv.fr).
- ANSSI — recommandations de sécurité pour les systèmes d'IA générative (cyber.gouv.fr).

Toute référence doit être vérifiée dans sa version en vigueur au jour de la consultation. Cette fiche est un support pédagogique et ne constitue pas un conseil juridique individualisé.